

Prime Stack Test Execution Report

Team: Prime Stack
Application under test: Frost Inventory and Shopping System
Report date: 19 May 2026

1. Execution Summary

Testing was performed for the Frost Inventory and Shopping System in the local development environment. The testing effort included automated backend functional tests, Playwright UI/usability scenarios, k6 performance and security scripts, and an OWASP ZAP automated scan of the backend API.

The final defect list contains ten fixed defects and two open manual usability findings. DEF-001 through DEF-012 are now the canonical IDs used across all reports.

2. Test Environment

Item	Value
Backend	Express API on <code>http://localhost:3000</code>
Frontend	Angular app on <code>http://localhost:4200</code>
Database	MySQL database <code>frost</code>
Functional tools	Jest, Supertest
Frontend/usability tool	Playwright
Performance/security script tool	k6
Security scanner	ZAP by Checkmarx 2.17.0

3. Execution Results by Test Type

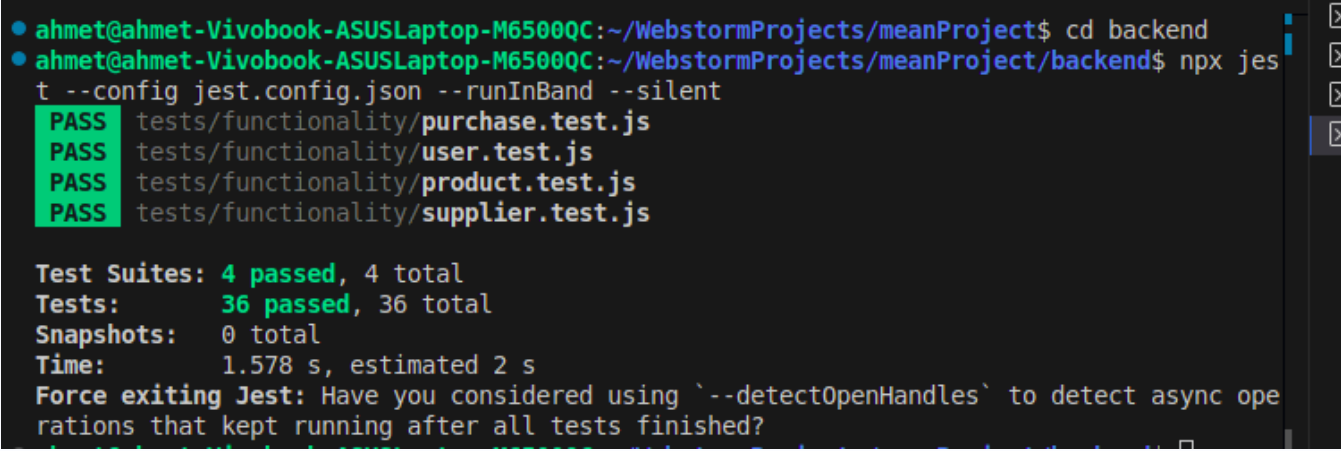
Test type	Planned	Evidence	Result summary
Functional API tests	36	<code>backend/tests/functionality</code>	Final run passed: 4 suites, 36 tests
Frontend usability checks	9 automated scenarios / 18 browser executions plus manual review	<code>frontend/tests/example.spec.ts</code> and teammate DOCX review	Final Playwright run passed in Chromium and Firefox: 18/18 executions; two open manual usability findings recorded
Performance tests	6	<code>backend/tests/performance/load-test.js</code>	Final k6 load run passed: HTTP error rate 0.00%, p95 53.38 ms
Security scripted tests	8 scripted checks	<code>backend/tests/performance/security-test.js</code>	Final k6 security run passed: 8/8 checks
ZAP scan	1 scan	<code>docs/testing/evidence/2026-05-14-ZAP-Secuirty-Report-.html</code>	Header findings recorded under DEF-008

4. Functional Test Execution

Before the fixes, the functional suite showed 3 failing tests. The failures were connected to missing/invalid email handling and purchase SQL interpolation.

After applying fixes, the final functional result was:

```
```text
Test Suites: 4 passed, 4 total
Tests: 36 passed, 36 total
```
```



```
● ahmet@ahmet-Vivobook-ASUSLaptop-M6500QC:~/WebstormProjects/meanProject$ cd backend
● ahmet@ahmet-Vivobook-ASUSLaptop-M6500QC:~/WebstormProjects/meanProject/backend$ npx jest
t --config jest.config.json --runInBand --silent
PASS tests/functionality/purchase.test.js
PASS tests/functionality/user.test.js
PASS tests/functionality/product.test.js
PASS tests/functionality/supplier.test.js

Test Suites: 4 passed, 4 total
Tests: 36 passed, 36 total
Snapshots: 0 total
Time: 1.578 s, estimated 2 s
Force exiting Jest: Have you considered using `--detectOpenHandles` to detect async operations that kept running after all tests finished?
```

Functional tests passed

5. Frontend Usability Test Execution

Frontend usability tests are written with Playwright. They cover:

- UT-001: Registration form entry.
- UT-002: Protected client dashboard redirects unauthenticated users.
- UT-003: Existing user login form submission.
- UT-004: Product catalog with supplier details.
- UT-005: Cart add, quantity update, and remove workflow.
- UT-006: Purchase from cart.
- UT-007: Profile view and edit modal opening.
- UT-008: Supplier management route protection.
- UT-009: Client profile username/email edit.

Final Playwright result:

```
```text
18 browser executions passed across Chromium and Firefox.
Overall result: PASSED
```
```

The expanded Playwright coverage exposed and verified fixes for profile/session display issues recorded as DEF-009 and DEF-010.

Readable Playwright usability-test summary

```
-----
PASS [chromium] UT-002: Protected client dashboard redirects unauthenticated users (2.8s)
PASS [chromium] UT-001: Login page supports registration form entry (3.2s)
PASS [chromium] UT-004: Client can view product catalog with supplier details (3.6s)
PASS [chromium] UT-008: Supplier management redirects unauthenticated users (1.3s)
PASS [chromium] UT-007: Client can view profile and open edit profile form (1.8s)
PASS [chromium] UT-006: Client can complete a purchase from cart (4.5s)
PASS [chromium] UT-005: Client can add, update, and remove a product in cart (4.7s)
PASS [firefox] UT-001: Login page supports registration form entry (2.9s)
PASS [firefox] UT-002: Protected client dashboard redirects unauthenticated users (3.0s)
PASS [firefox] UT-009: Client can edit profile username and email (2.6s)
PASS [firefox] UT-005: Client can add, update, and remove a product in cart (4.7s)
PASS [firefox] UT-006: Client can complete a purchase from cart (3.7s)
PASS [firefox] UT-004: Client can view product catalog with supplier details (4.3s)
PASS [chromium] UT-003: Login form accepts existing user credentials (12.0s)
PASS [firefox] UT-008: Supplier management redirects unauthenticated users (1.2s)
PASS [firefox] UT-003: Login form accepts existing user credentials (12.2s)
```

Overall result: PASSED

Playwright final passing summary

Additional teammate manual usability review notes:

| Metric / observation | Result | Notes |
|---|-----------------------------|---|
| Think-aloud session | Conducted with 3 real users | Local development environment |
| Average completion time for registration flow | 42 seconds | Registration was functional, but visual inconsistency slowed users down |
| Average completion time for product discovery | 115 seconds | Product discovery took longer because search/filtering is missing |
| Average satisfaction score | 3.8 / 5.0 | Users found the dashboard clean but lacking essential e-commerce tools |

6. Performance Test Execution

The k6 load test uses this load profile:

| Stage | Duration | Target virtual users |
|-------------|------------|----------------------|
| Normal load | 30 seconds | 5 |
| Load ramp | 1 minute | 20 |
| Stress | 30 seconds | 50 |
| Recovery | 30 seconds | 0 |

Performance acceptance thresholds:

- 95% of requests should complete in under 500 ms.
- Error rate should stay below 10%.

The final k6 load result was valid because the backend returned real HTTP responses throughout the run:

```text

```
PASS PT-001 auth status returns 200 as expected: 872/872 passed
PASS PT-002 product list returns 200 as expected: 872/872 passed
PASS PT-003 products with details returns 200 as expected: 872/872 passed
PASS PT-004 supplier list returns 200 as expected: 872/872 passed
```

PASS PT-005 login returns 200 as expected: 872/872 passed

HTTP error rate: 0.00%

Slow response check rate: 0.00%

95th percentile response time: 53.38ms

...

#### Readable k6 load-test summary

```

PASS PT-001 auth status returns 200 as expected: 872/872 passed
PASS PT-001 auth status responds under 200ms: 872/872 passed
PASS PT-002 product list returns 200 as expected: 872/872 passed
PASS PT-002 product list responds under 300ms: 872/872 passed
PASS PT-003 products with details returns 200 as expected: 872/872 passed
PASS PT-003 products with details responds under 400ms: 872/872 passed
PASS PT-004 supplier list returns 200 as expected: 872/872 passed
PASS PT-004 supplier list responds under 300ms: 872/872 passed
PASS PT-005 login returns 200 as expected: 872/872 passed
PASS PT-005 login responds under 500ms: 872/872 passed
```

HTTP error rate: 0.00%

Slow response check rate: 0.00%

95th percentile response time: 53.44ms

running (2m33.1s), 00/50 VUs, 872 complete and 0 interrupted iterations

k6 load final passing summary

An earlier invalid k6 load result is retained as evidence of an environment mistake. It showed `status 0`, `http_req_failed 100%`, and `data_received 0 B`, which means k6 did not receive HTTP responses from the backend.

```
http_req_duration
✓ 'p(95)<500' p(95)=0s

■ TOTAL RESULTS

checks_total.....: 8880 58.521834/s
checks_succeeded...: 50.00% 4440 out of 8880
checks_failed.....: 50.00% 4440 out of 8880

x PT-001 status endpoint returns 200
 L 0% - ✓ 0 / x 888
✓ PT-001 response time under 200ms
x PT-002 products endpoint returns 200
 L 0% - ✓ 0 / x 888
✓ PT-002 response time under 300ms
x PT-003 products with details returns 200
 L 0% - ✓ 0 / x 888
✓ PT-003 response time under 400ms
x PT-004 suppliers endpoint returns 200
 L 0% - ✓ 0 / x 888
✓ PT-004 response time under 300ms
x PT-005 login endpoint returns 200
 L 0% - ✓ 0 / x 888
✓ PT-005 login response time under 500ms

CUSTOM
error_rate.....: 100.00% 4440 out of 4440
response_time.....: avg=0 min=0 med=0 max=0 p(90)=0 p(95)=0

HTTP
http_req_duration....: avg=0s min=0s med=0s max=0s p(90)=0s p(95)=0s
http_req_failed.....: 100.00% 4440 out of 4440
http_reqs.....: 4440 29.260917/s

EXECUTION
iteration duration...: avg=3s min=3s med=3s max=3s p(90)=3s p(95)=3s
iterations.....: 888 5.852183/s
vus.....: 1 min=1 max=50
vus_max.....: 50 min=50 max=50

NETWORK
data_received.....: 0 B 0 B/s
data_sent.....: 0 B 0 B/s

running (2m31.7s), 00/50 VUs, 888 complete and 0 interrupted iterations
default ✓ [=====] 00/50 VUs 2m30s
ERROR[0152] thresholds on metrics 'error_rate' have been crossed
abstet@abstet-VirtualBook: /$ curl -s https://api.github.com/repos/abstet/abstet | jq .
```

k6 load run with unreachable backend

## 7. Security Test Execution

The scripted security test covers:

- SQL injection on login.
- SQL injection in product ID parameter.
- XSS payload in registration username.
- Unauthenticated profile access.
- Mass assignment using `role: "admin"`.
- Oversized login payload.
- Unauthenticated access to `/User/users`.
- Authenticated access to `/User/profile` after login.

The final k6 security run passed all scripted checks:

```
```text
PASS ST-001 SQL injection on login is rejected: 1/1 passed
PASS ST-002 SQL injection on product ID is rejected: 1/1 passed
PASS ST-003 XSS payload in username is handled: 1/1 passed
PASS ST-004 protected route rejects unauthenticated request: 1/1 passed
PASS ST-005 mass assignment does not grant admin role: 1/1 passed
PASS ST-006 oversized payload does not crash server: 1/1 passed
PASS ST-007 user list requires authentication: 1/1 passed
PASS ST-011 authenticated user can access own profile: 1/1 passed
```
```

### Readable k6 security-test summary

```

PASS ST-001 SQL injection on login is rejected: 1/1 passed
PASS ST-002 SQL injection on product ID is rejected: 1/1 passed
PASS ST-003 XSS payload in username is handled: 1/1 passed
PASS ST-004 protected route rejects unauthenticated request: 1/1 passed
PASS ST-005 mass assignment does not grant admin role: 1/1 passed
PASS ST-006 oversized payload does not crash server: 1/1 passed
PASS ST-007 user list requires authentication: 1/1 passed
PASS ST-011 authenticated user can access own profile: 1/1 passed

running (00m03.7s), 0/1 VUs, 1 complete and 0 interrupted iterations
```

k6 security final passing summary

One earlier uploaded k6 security run also shows `status 0` and `data_received 0 B`. That specific run is invalid for pass/fail grading because k6 could not reach the backend. The security defects themselves were still confirmed by route review and earlier scripted checks, then fixed in code.

```

ahmet@ahmet-Vivobook-ASUSLaptop-M6500QC:~/WebstormProjects/meanProject/backend$ k6 run
tests/performance/security-test.js
INFO[0003] ST-007 Unauth User List: 0 - null source=console

■ TOTAL RESULTS

checks_total.....: 7 2.322529/s
checks_succeeded...: 57.14% 4 out of 7
checks_failed.....: 42.85% 3 out of 7

✓ ST-001 SQL injection on login is rejected
✓ ST-002 SQL injection on product ID is rejected
✓ ST-003 XSS payload in username is handled
x ST-004 protected route rejects unauthenticated request
 ↳ 0% — ✓ 0 / ✗ 1
✓ ST-005 mass assignment does not grant admin role
x ST-006 oversized payload does not crash server
 ↳ 0% — ✓ 0 / ✗ 1
x ST-007 user list requires authentication
 ↳ 0% — ✓ 0 / ✗ 1

HTTP
http_req_duration....: avg=0s min=0s med=0s max=0s p(90)=0s p(95)=0s

http_req_failed.....: 100.00% 7 out of 7
http_reqs.....: 7 2.322529/s

EXECUTION
iteration_duration...: avg=3.01s min=3.01s med=3.01s max=3.01s p(90)=3.01s p(95)=3.01s
iterations.....: 1 0.33179/s
vus.....: 1 min=1 max=1
vus_max.....: 1 min=1 max=1

NETWORK
data_received.....: 0 B 0 B/s
data_sent.....: 0 B 0 B/s

running (00m03.0s), 0/1 VUs, 1 complete and 0 interrupted iterations
default ✓ [=====] 1 VUs 00m03.0s/10m0s 1/1 shared iters
ahmet@ahmet-Vivobook-ASUSLaptop-M6500QC:~/WebstormProjects/meanProject/backend$

```

k6 security run with unreachable backend

## 8. ZAP Scan Results

ZAP report details:

| Attribute     | Value                                                      |
|---------------|------------------------------------------------------------|
| Tool          | ZAP by Checkmarx                                           |
| Version       | 2.17.0                                                     |
| Generated     | Thu 14 May 2026, 14:16:40                                  |
| Site          | http://localhost:3000                                      |
| Evidence file | docs/testing/evidence/2026-05-14-ZAP-Security-Report-.html |

ZAP alert summary:

| Alert                                            | Risk          | Confidence | Evidence                                                   |
|--------------------------------------------------|---------------|------------|------------------------------------------------------------|
| CSP failure to define directive with no fallback | Medium        | High       | default-src 'none' without frame-ancestors and form-action |
| Server leaks X-Powered-By                        | Low           | Medium     | X-Powered-By: Express                                      |
| X-Content-Type-Options header missing            | Low           | Medium     | /Product/ did not include nosniff                          |
| User Agent Fuzzer                                | Informational | Medium     | Response changed for an old IE user agent                  |

## 9. Confirmed Defects

| ID      | Title                                                                             | Severity | Status |
|---------|-----------------------------------------------------------------------------------|----------|--------|
| DEF-001 | Missing/invalid email returns 500 instead of 400                                  | Medium   | Fixed  |
| DEF-002 | Template literal bug in <code>getPurchaseByUserId</code>                          | Medium   | Fixed  |
| DEF-003 | <code>SupplierRoute</code> POST has no error handling                             | Medium   | Fixed  |
| DEF-004 | Login route hardcodes status 500                                                  | Medium   | Fixed  |
| DEF-005 | Mass assignment allows any user to register as admin                              | Critical | Fixed  |
| DEF-006 | <code>/User/users</code> exposes all user data without authentication             | High     | Fixed  |
| DEF-007 | XSS payload stored in database without sanitization                               | Medium   | Fixed  |
| DEF-008 | Missing security headers                                                          | Low      | Fixed  |
| DEF-009 | Login stores value objects in session, causing <code>[object Object]</code> in UI | Medium   | Fixed  |
| DEF-010 | Profile refresh assigns wrapped API response as user state                        | Medium   | Fixed  |
| DEF-011 | Inconsistent background color on registration input fields                        | Low      | Open   |
| DEF-012 | Missing search and filtering functionality for product discovery                  | Medium   | Open   |

## 10. Overall Assessment

The application now has stronger automated coverage for core API behavior, UI workflows, cart/purchase/profile behavior, and session security. The latest backend load test, k6 security script, and Playwright usability suite all passed with the backend and frontend running locally.

## 11. Evidence List

| Evidence                                  | File                                                                               |
|-------------------------------------------|------------------------------------------------------------------------------------|
| ZAP full report                           | <code>docs/testing/evidence/2026-05-14-ZAP-Secuirty-Report-.html</code>            |
| DEF-001 before/after evidence             | <code>docs/testing/evidence/defects/def-001-*.png</code>                           |
| DEF-002 before/after evidence             | <code>docs/testing/evidence/defects/def-002-*.png</code>                           |
| DEF-004 login status fix                  | <code>docs/testing/evidence/defects/def-004-login-statuscode-fix.png</code>        |
| DEF-005 mass-assignment fix               | <code>docs/testing/evidence/defects/def-005-mass-assignment-fix.png</code>         |
| DEF-006 user-list auth fix                | <code>docs/testing/evidence/defects/def-006-user-list-auth-fix.png</code>          |
| DEF-007 XSS validation fix                | <code>docs/testing/evidence/defects/def-007-xss-username-validation-fix.png</code> |
| DEF-008 security headers fix              | <code>docs/testing/evidence/defects/def-008-security-headers-fix.png</code>        |
| Functional pass screenshot                | <code>docs/testing/evidence/defects/functional-after-36-passed.png</code>          |
| Playwright product catalog screenshot     | <code>frontend/tests/screenshots/UT-004-product-catalog.png</code>                 |
| Playwright cart workflow screenshot       | <code>frontend/tests/screenshots/UT-005-cart-workflow.png</code>                   |
| Playwright purchase completion screenshot | <code>frontend/tests/screenshots/UT-006-purchase-complete.png</code>               |

| Evidence                                        | File                                                                   |
|-------------------------------------------------|------------------------------------------------------------------------|
| Playwright profile screenshot                   | frontend/tests/screenshots/UT-007-profile.png                          |
| Playwright supplier route protection screenshot | frontend/tests/screenshots/UT-008-supplier-protected.png               |
| Playwright profile edit screenshot              | frontend/tests/screenshots/UT-009-profile-edit.png                     |
| Playwright final passing summary                | docs/testing/evidence/test-output/playwright-summary.png               |
| k6 load final passing summary                   | docs/testing/evidence/test-output/k6-load-summary.png                  |
| k6 security final passing summary               | docs/testing/evidence/test-output/k6-security-summary.png              |
| DEF-011 registration field color evidence       | docs/testing/evidence/friend-doc/def-011-registration-input-colors.png |
| DEF-012 missing search/filter evidence          | docs/testing/evidence/friend-doc/def-012-dashboard-no-search.png       |
| Invalid k6 load run                             | docs/testing/evidence/defects/performance-unreachable-run.png          |
| Invalid k6 security run                         | docs/testing/evidence/defects/security-unreachable-run.png             |